



Cybersecurity Governance Guide for Regulated Organizations

Technical controls, regulatory frameworks, and continuous monitoring for cybersecurity governance.

Regulatory Requirements

Regulated organizations face specific cybersecurity mandates:

- SEC Regulation S-P: Requires written policies for safeguarding customer information and records.
- SEC Regulation S-ID: Identity theft red flags programs for financial institutions.
- FINRA Rule 4370: Business continuity planning requirements including cybersecurity incidents.
- HIPAA Security Rule: Administrative, physical, and technical safeguards for ePHI.
- NIST Cybersecurity Framework: Identify, Protect, Detect, Respond, Recover.

Technical Control Framework

A comprehensive cybersecurity governance program requires controls across multiple domains:

- ✓ Endpoint Protection: EDR/XDR deployment, patch management, device encryption.
- ✓ Network Security: Firewall management, network segmentation, intrusion detection.
- ✓ Identity & Access Management: MFA enforcement, privileged access management, SSO.
- ✓ Email Security: Advanced threat protection, DMARC/DKIM/SPF, phishing simulation.
- ✓ Data Loss Prevention: Content inspection, policy enforcement, encryption at rest and in transit.
- ✓ Cloud Security: CASB deployment, configuration monitoring, access controls.

Incident Response Framework

Every regulated organization needs a tested incident response plan:

- Detection: Automated alerting from SIEM, EDR, and network monitoring tools.
- Triage: Severity classification and escalation procedures within 15 minutes.
- Containment: Isolation procedures for compromised systems and accounts.
- Notification: Regulatory notification timelines (72 hours GDPR, state breach laws).
- Recovery: System restoration from verified clean backups.
- Post-Incident: Root cause analysis and control improvements within 30 days.

Implementation Checklist

- Deploy EDR/XDR across all endpoints with 24/7 monitoring
- Implement MFA for all user accounts and administrative access
- Configure SIEM with correlation rules for regulatory compliance
- Establish vulnerability management program with SLA-based remediation
- Deploy email security with advanced threat protection
- Implement network segmentation and micro-segmentation
- Create and test incident response plan quarterly
- Conduct annual penetration testing and red team exercises

Continuous Monitoring

Cybersecurity governance requires ongoing vigilance:

- Real-time threat monitoring through SOC or managed detection and response.
- Monthly vulnerability scanning and quarterly penetration testing.
- Annual cybersecurity risk assessments aligned with regulatory requirements.
- Continuous compliance monitoring against SEC, FINRA, and HIPAA requirements.
- Regular security awareness training with phishing simulations.
- Board-level cybersecurity reporting on a quarterly basis.